

Conditional Access Unscripted

10 Years of Lessons Learned

Ru Campbell MVP

or: last minute session cause a speaker pulled out
(only a fool would trust anything I say)

Hello



Ru Campbell

Practice Lead – Microsoft Security

 Threatscape

MVP

6x Microsoft Security

Author

Mastering Microsoft 365 Defender
Defender for Endpoint in Depth 2nd Ed
Mastering Microsoft Defender XDR

Instructor

Cybersecurity, LinkedIn Learning

Organiser

M365 Security & Compliance User Group

**Floating
head**

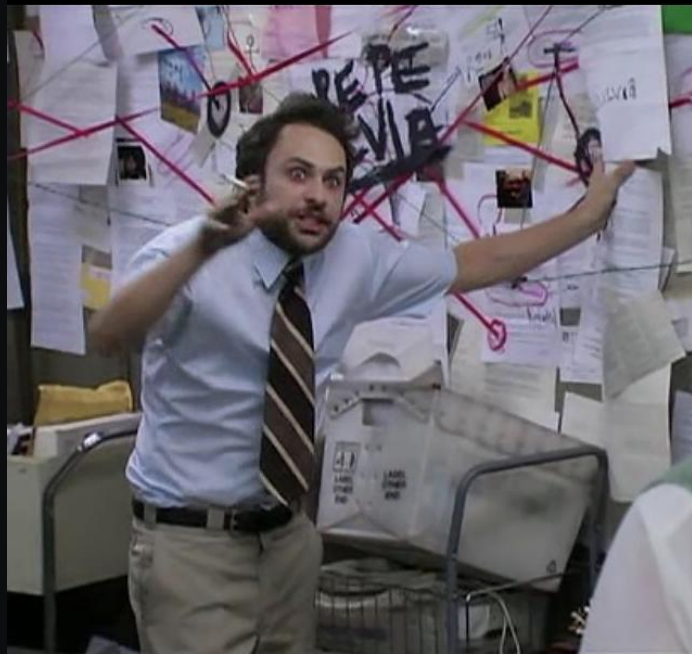
[YouTube.com/@Threatscape](https://www.youtube.com/@Threatscape)



2016 to 2026



World
history



Entra
history

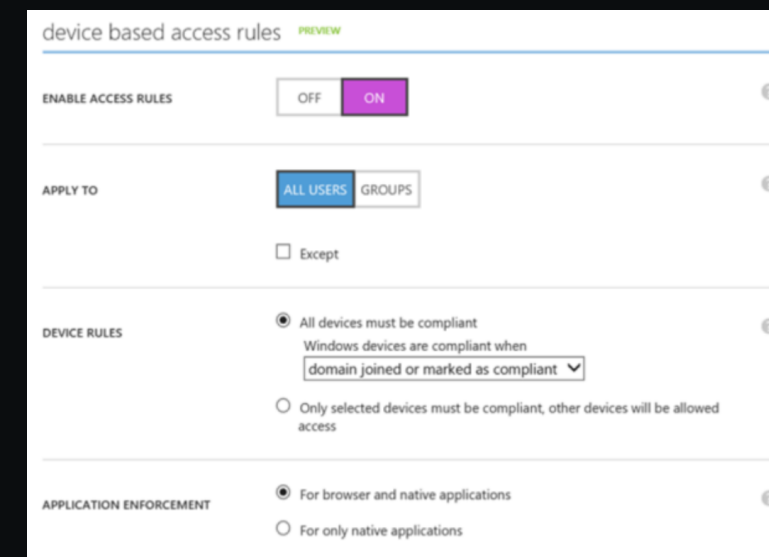
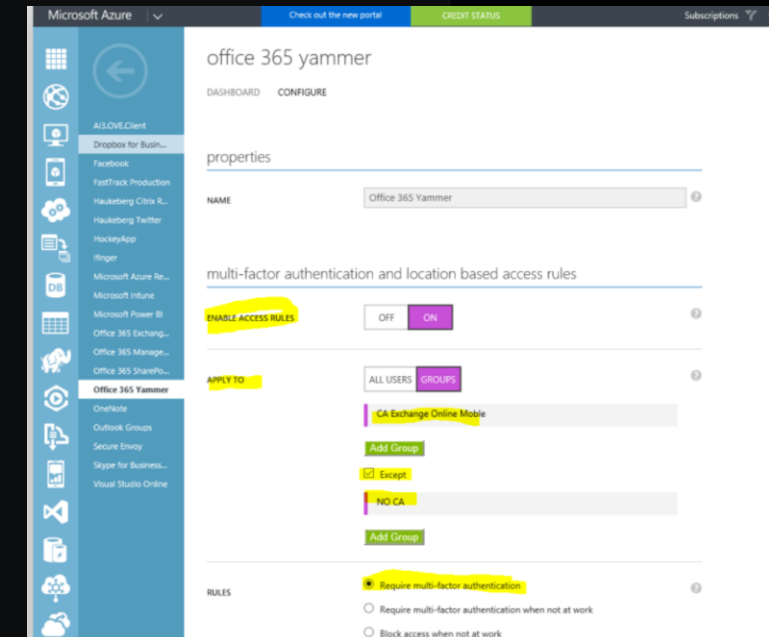
2016

Per-app MFA and network locations

Admins could require MFA for selected apps and include trusted network locations in the policy

Device-based Conditional Access

Device state available as a condition



2017

SPO and EXO restrictions for unmanaged devices

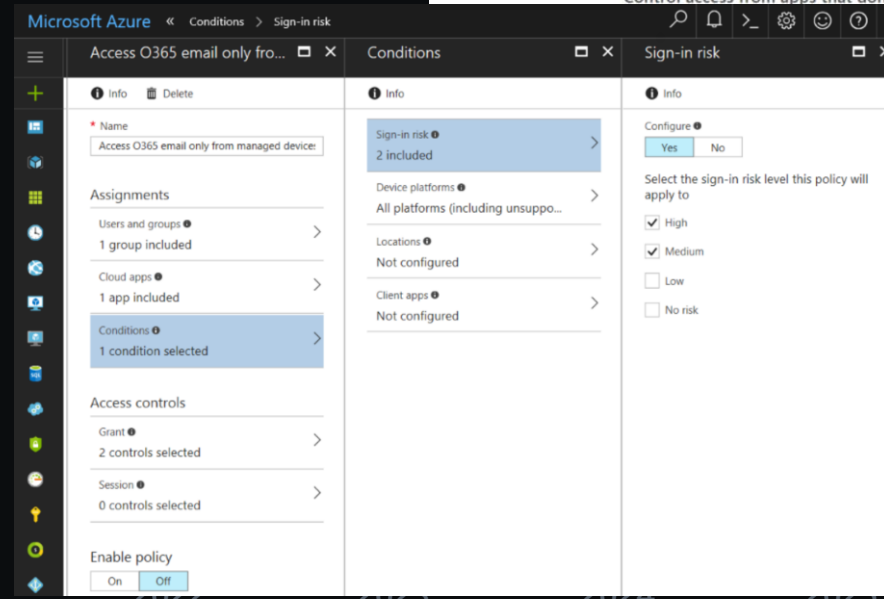
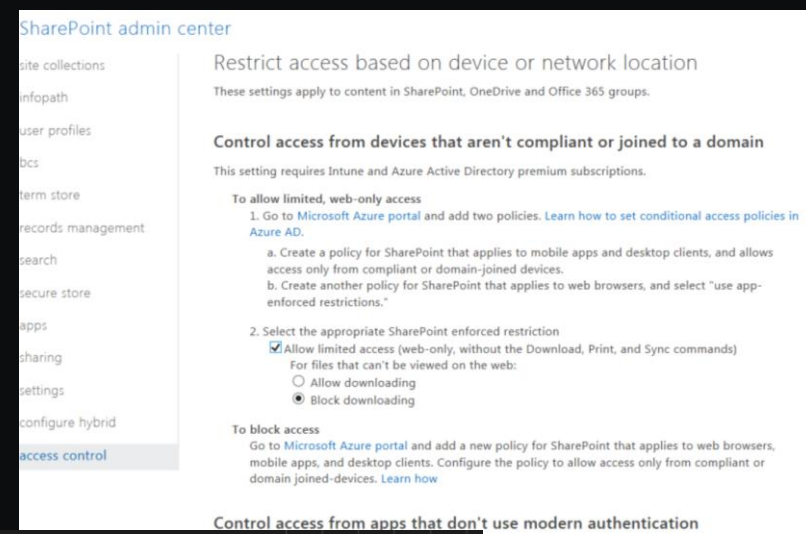
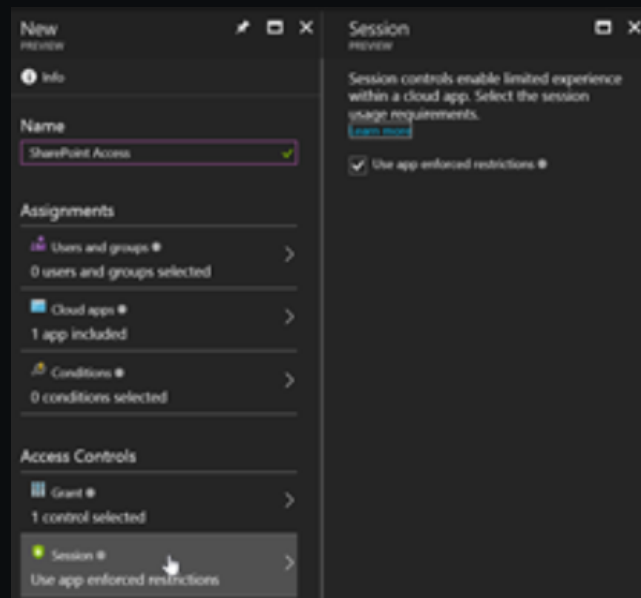
First glimpse at session policies

Unified Conditional Access experience

One combined experience, also brought in AAD IDP

Approved client apps

Separate MFA and device policy experiences combined into one interface.

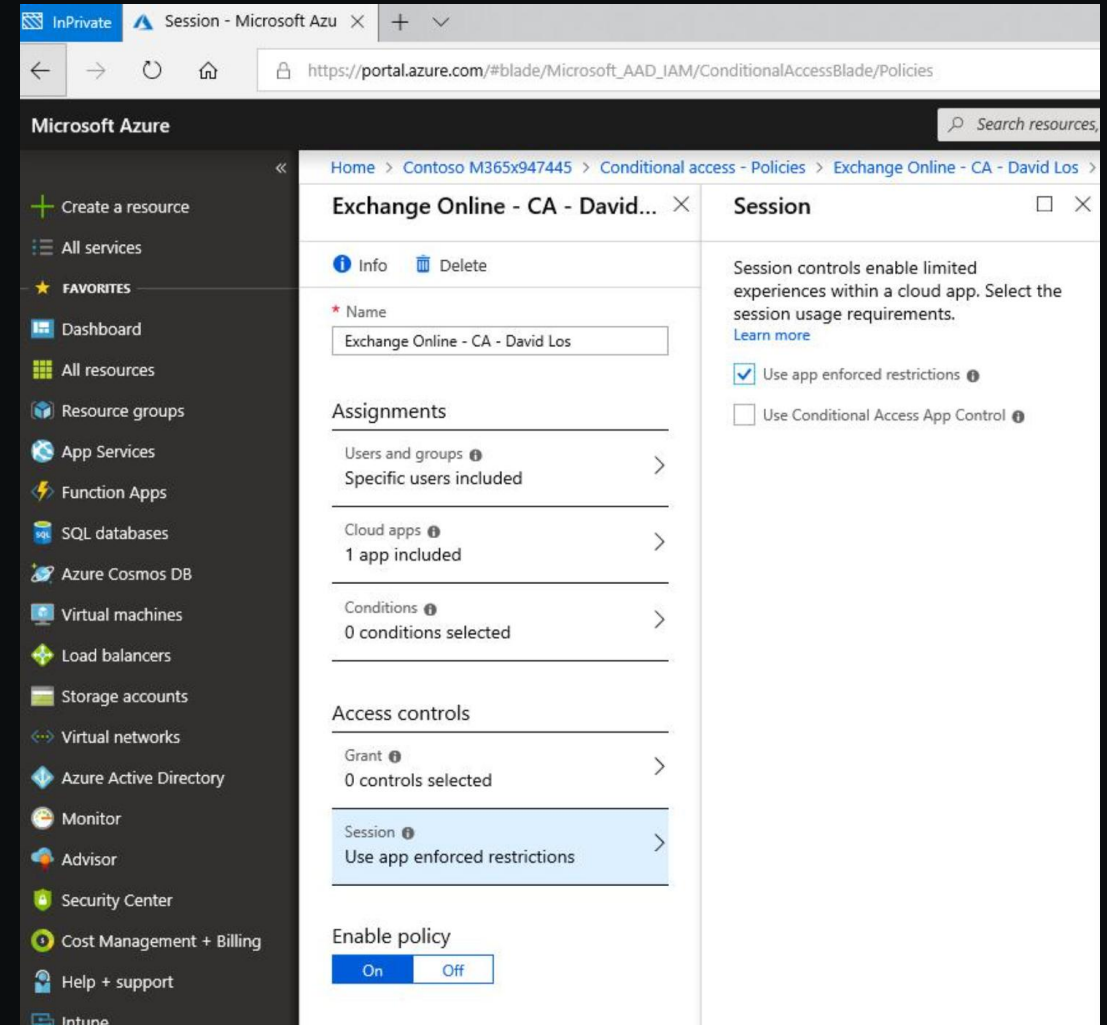


2018

Conditional Access App Control

Integration with Microsoft Cloud App Security (MDA!)

What If tool
Simulate stuff



2019

Report-only mode

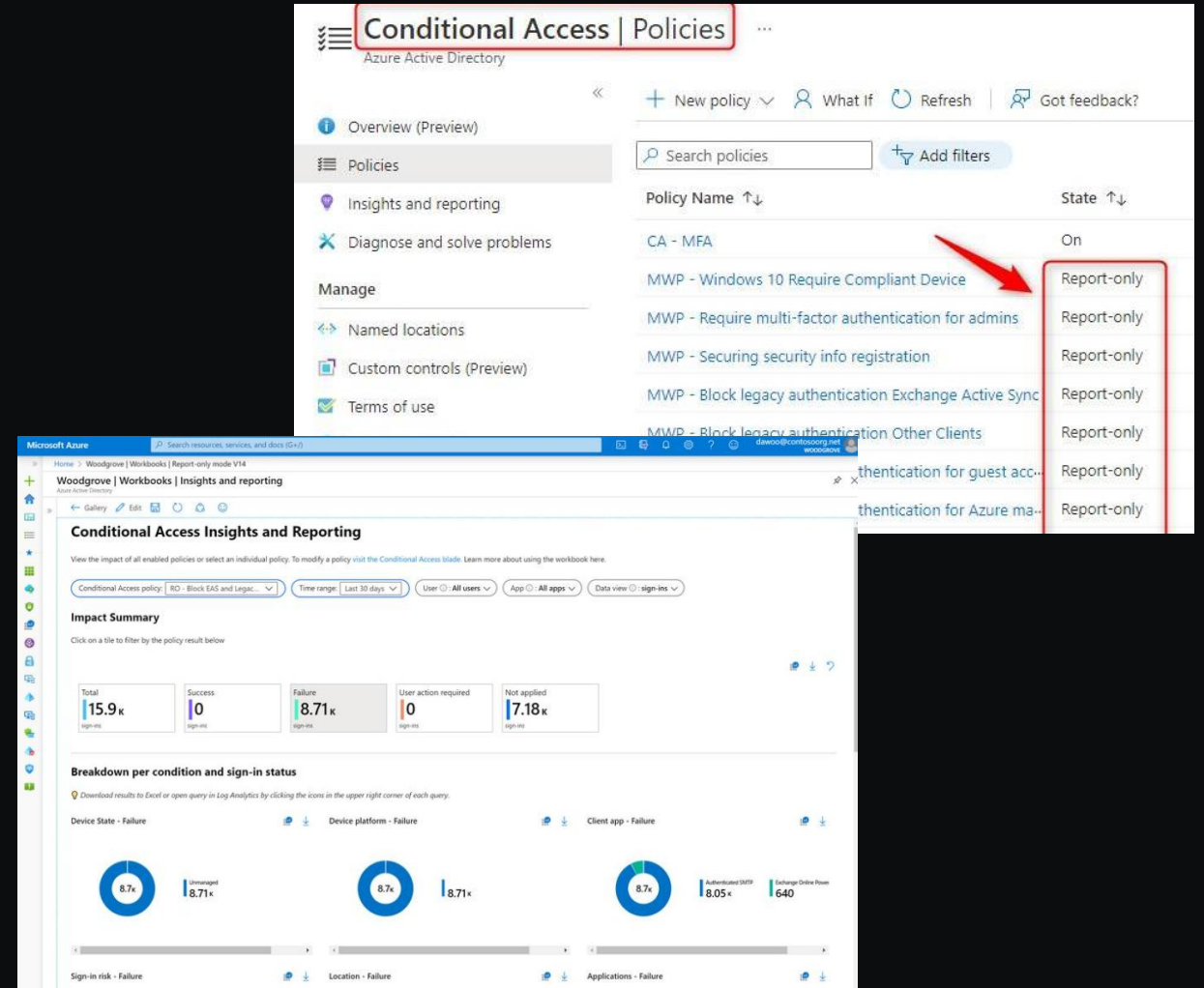
See policy result without enforcement

Insights and reporting workbook

OOTB admin summaries of CA

Session options

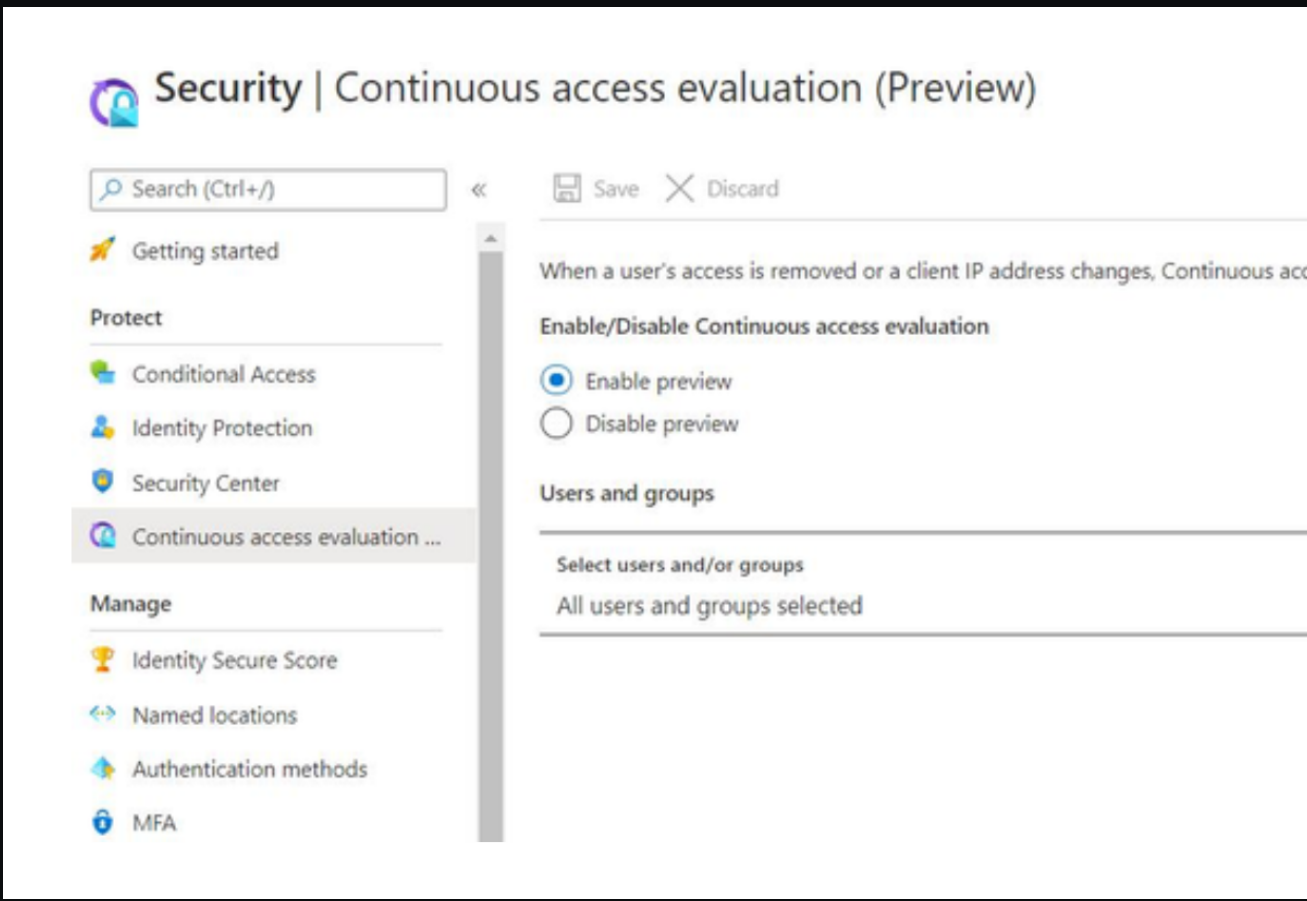
SIF + persistent browser session controls



2020

Continuous Access Evaluation

React quickly to events such as account disablement or a location change.



2021

Auth contexts

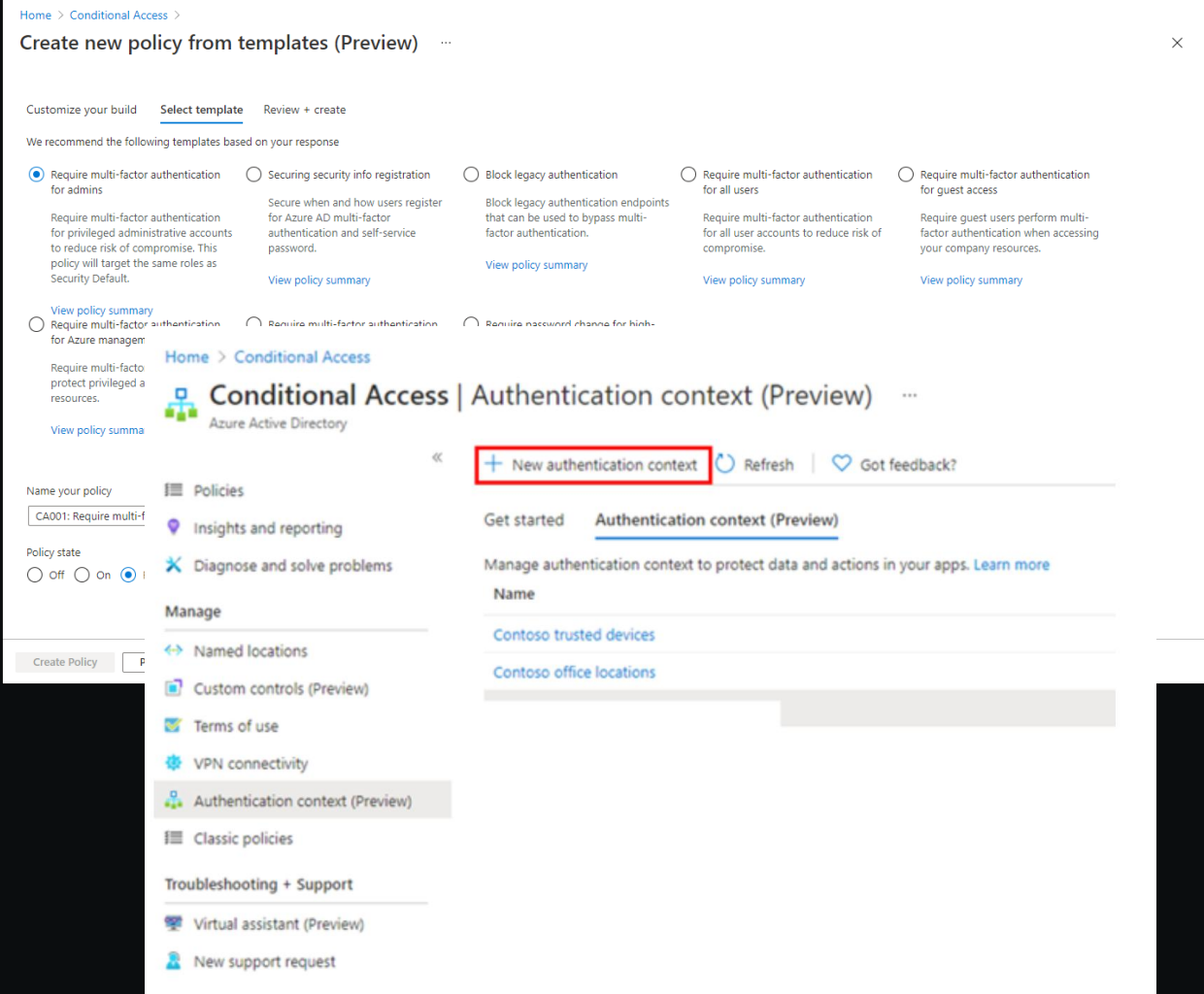
Invoke CA during in-app experience.

Workload identities

Location-based block policies to owned service principals.

Policy templates

They're ok.



Home > Conditional Access >

Create new policy from templates (Preview)

Customize your build **Select template** Review + create

We recommend the following templates based on your response

- ☒ **Require multi-factor authentication for admins**
Require multi-factor authentication for privileged administrative accounts to reduce risk of compromise. This policy will target the same roles as Security Default.
[View policy summary](#)
- ☐ **Secure when and how users register for Azure AD multi-factor authentication and self-service password.**
[View policy summary](#)
- ☐ **Block legacy authentication**
Block legacy authentication endpoints that can be used to bypass multi-factor authentication.
[View policy summary](#)
- ☐ **Require multi-factor authentication for all users**
Require multi-factor authentication for all user accounts to reduce risk of compromise.
[View policy summary](#)
- ☐ **Require multi-factor authentication for guest access**
Require guest users perform multi-factor authentication when accessing your company resources.
[View policy summary](#)

Home > Conditional Access

Conditional Access | Authentication context (Preview)

Azure Active Directory

« **+ New authentication context** Refresh | Got feedback?

Get started **Authentication context (Preview)**

Manage authentication context to protect data and actions in your apps. [Learn more](#)

Name

- [Contoso trusted devices](#)
- [Contoso office locations](#)

Manage

- [Named locations](#)
- [Custom controls \(Preview\)](#)
- [Terms of use](#)
- [VPN connectivity](#)
- [Authentication context \(Preview\)](#)**
- [Classic policies](#)

Troubleshooting + Support

- [Virtual assistant \(Preview\)](#)
- [New support request](#)

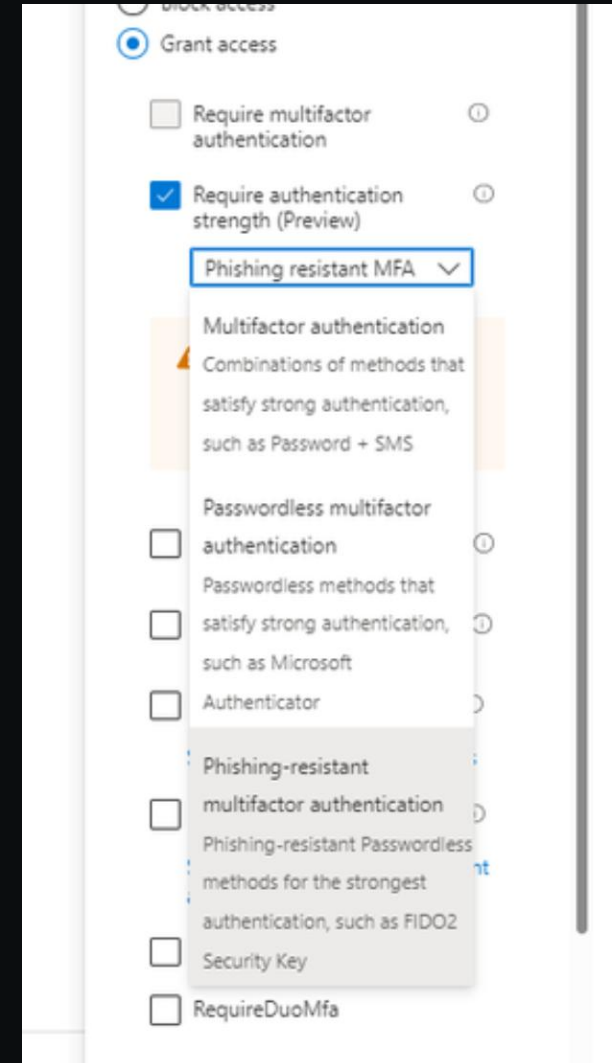
2022

Authentication strengths

Require specific types of MFA auth instead of any method that satisfied MFA.

Filters for applications

Target applications dynamically using custom security attributes



2023

Token protection

Binding refresh tokens to the device

GSA

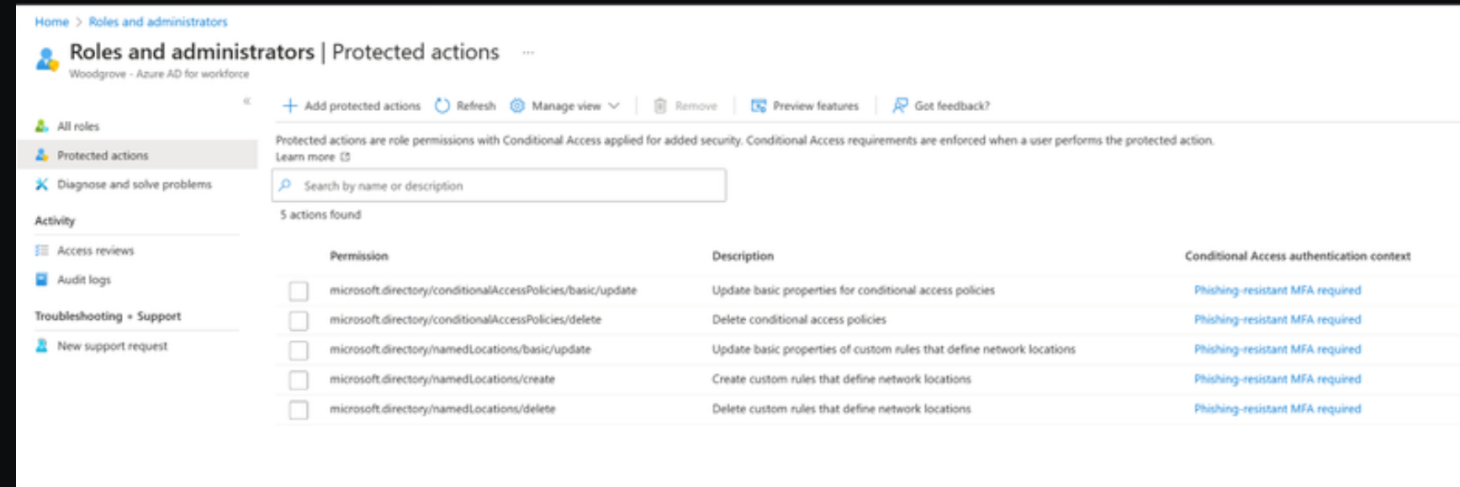
Entra becomes more than identity brand

Protected actions

CA when sensitive operations happen

Strict location enforcement with CAE

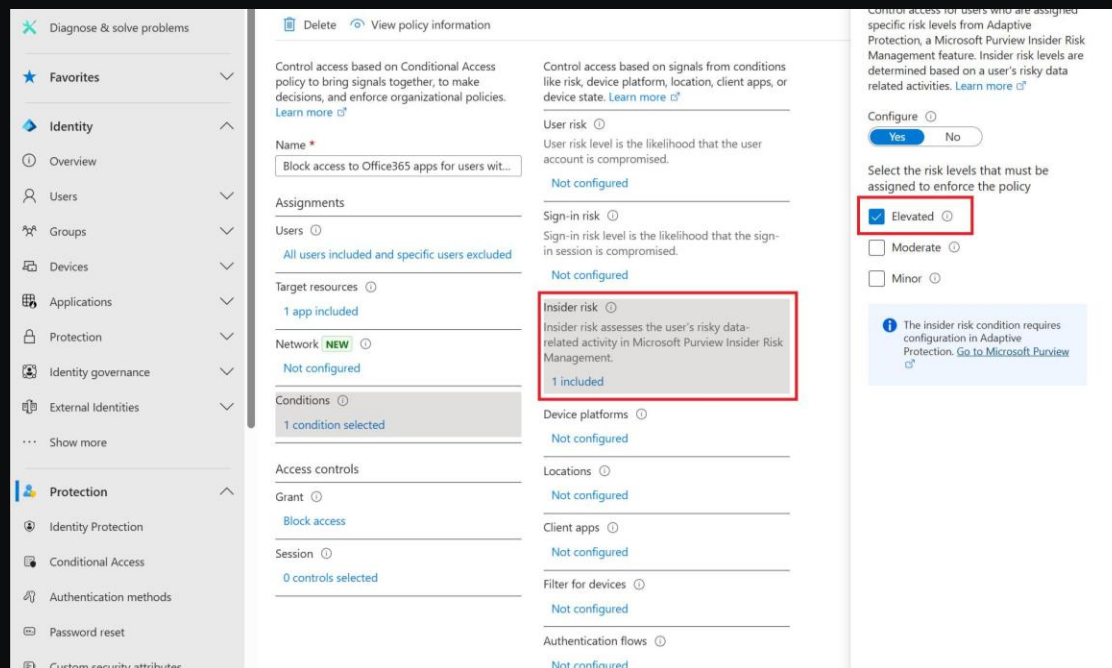
Rapidly invalidate supported sessions when the network location changes.



2024

Insider risk Purview adaptive protection

Authentication flows conditions Control device code flow and authentication transfer



2025

Optimization Agent

First Microsoft agent for CA

What If API

Microsoft Graph query capability

Conditional Access Optimization Agent

Analyze my tenant

Remove agent

Chat with agent (Preview)

Give Microsoft feedback

Overview

Activities

Suggestions

Settings

Agent summary

From Jun 1, 2025 to Jul 1, 2025

In the past 30 days, **0 suggestions have been applied to protect 0 users and 0 applications.** Conditional Access Optimization agent has analyzed a total of 1 new user and 0 new applications.

Unprotected users discovered

Unprotected apps discovered

Sign-ins protected

Security compute units used

0

0

0

0.32

Agent is active

Agent finished running on July 1, 2025 at 1:10 PM. [View run](#)

The agent is next scheduled to run on July 2, 2025 at 1:05 PM

Recent suggestions

AI-generated content may be incorrect. Check it for accuracy.

View all

View the agent's suggestions about policy updates and new policies that were created in report-only mode.

Suggested next steps	Actions taken by agent	Time generated	Status
Add 1 user to existing policy Require multifactor authentication for all users	Suggested policy update	6/5/25, 1:43:53 PM	Not applied

Review suggestion

2026

Phased rollout expands

Support for any eligible report-only policy

Conditional Access for agent user accounts

Additional license 🤖

External MFA

Supersedes 'custom controls'

Phased rollout (Preview) ...

Require password change for high-risk users (deploying)

 Pause  Resume  Manually rollout phases

The Conditional Access Optimization agent is executing the rollout plan for this policy. It will progress through each phase every **2** days, based on your agent settings. Rollout will be canceled if the policy shows increased impact on end users or if an admin makes significant changes to the policy.



 Pilot
Pilot Group

No sign-ins applied 88 5 users Aug 27, 2025 
[Monitoring sign-in success](#)

 Early Adoption

88 2 users Aug 29, 2025 

What does *CA really* protect?



Cloud
app



Target
resource



Tenant-local
service principal
representing the
OAuth resource
server that is the
intended audience
of the access
token.

Refresh token/PRT

Used to request new tokens from Microsoft Entra ID. It is not presented to the resource.

ID token

Sent to the client. It describes the signed-in user and is not used to call an API.

Access token

Sent to the resource. Its audience and claims describe the access that was granted.

Thank you for coming to my TED talk.